Exercise

Malware Detection & Intelligence Analysis

This exercise aims to introduce signature-based detection and allow you to develop an understanding on interpreting results in malware analysis. You will use the EICAR test file for this exercise. Please research the EICAR test file before attempting to work on this exercise.

The EICAR file is not real malware. It is a standard anti-virus test string used to verify detection systems. You **MUST NOT** upload any real malicious binaries. Please us your SANS SIFT VM for this exercise.

Task

Please follow the instructions to complete the exercise:

1. **Obtain the EICAR Test String**

Create a new text file and paste the following exact string:

```
X5O!P%@AP[4\PZX54(P^)7CC)7}$EICAR-STANDARD-ANTIVIRUS-TEST-FILE!$H+H*
```

You can save the file as 'eicar.com'.

2. **Static Characteristics**

i. Without uploading the file:
   a. Generate its SHA256 hash – You may use a tool such as Hash File Online.
   b. Research on VirusTotal to explore what the tool does if you have never worked with that before.
   c. Upload only the hash to VirusTotal.
   d. Review detection results.

ii. Respond to the following questions:

   a. How many engines detect it? ……

   b. What names are used to describe it? ……

   c. Is it classified as ransomware, trojan, worm, etc.? ……

d. What does this tell you about AV signature naming? ……

3. Interpretation

i. Use Virus Total to:

a. Examine the detection tab.
b. Examine the behaviour tab (if present).
c. Examine community comments.

ii. Respond to the following questions:

a. Does VirusTotal indicate malicious behaviour? ……

b. Are there any network indicators? ……

c. Is there any MITRE ATT&CK mapping? ……

4. Incident Planning

Assume your organisation detects this file on a workstation. You want to plan your next steps based on your initial analysis. Please attempt to respond to the following questions:

a. Is this a confirmed compromise? ……

b. Would you isolate the machine? ……

c. What verification steps would you take? ……

d. Could this be a false positive? ……

e. What logs would you check? ……